

Scenario 1 Prompt

LLM-Integrated Authentication Assistant System

You are a cybersecurity threat modelling expert specializing in LLM-integrated systems.

Perform a detailed threat modelling analysis for the following system.

The analysis must be based strictly on the provided architecture and data flows. Do not invent components, data stores, or responsibilities that are not described.

System Name:

LLM-Integrated Authentication Assistant System

System Objective:

The system provides user authentication functionality with an AI chatbot assistant that helps users with authentication-related questions and provides general account assistance. The AI component is only an assistance layer and must never perform authentication decisions, session management, credential verification, or account modifications.

Architecture Description:

Trust Boundary 1:

External User Environment (untrusted)

Entity:

EE1 End User

The user can:

- register an account
- submit login requests
- ask chatbot questions

All user inputs, including chatbot prompts, must be considered potentially malicious.

Application Environment (trusted application logic)

Process P1:

Web Frontend Interface

Responsibilities:

- receives user registration requests
- receives login requests
- receives chatbot questions
- displays responses

P1 does not authenticate users directly.

Process P2:

Authentication Service

Responsibilities:

- creates accounts
- verifies user credentials
- communicates with the user database
- performs authentication decisions

P2 is the only component responsible for authentication.

Process P3:
Session Management Module

Responsibilities:

- creates sessions after successful authentication
- manages session lifecycle
- stores and validates session information

Session tokens must not be exposed to the AI components.

Process P4:
AI Chatbot Component

Responsibilities:

- answers user questions
- provides authentication-related assistance
- retrieves approved documentation/context

Restrictions:

- cannot authenticate users
- cannot verify credentials
- cannot access password hashes
- cannot access session tokens
- cannot modify accounts

Process P5:
LLM Integration Service

Responsibilities:

- prepares prompts
- sends approved context to external LLM
- receives generated responses
- performs application-level response handling

Data Store DS1:
User Database

Contains:

- usernames
- salted password hash values
- account information
- authentication records

Plaintext passwords are not stored.

Data Store DS2:
Session Storage

Contains:

- session identifiers
- session metadata
- token-related information

Data Store DS3:
Knowledge Base / Context Repository

Contains:

- approved authentication documentation
- chatbot guidance information

Does not contain:

- passwords
- password hashes
- session tokens
- API keys

External Entity EE2:
External LLM Provider

Characteristics:

- third-party service
- outside application security control

Only sanitized prompts and authorization-approved context are sent.

No:

- passwords
- password hashes
- session tokens
- secrets

may cross this boundary.

Important Data Flow Assumptions:

1. Authentication decisions are performed only by P2.
2. Session lifecycle is controlled only by P3.
3. AI components cannot bypass authentication or authorisation.
4. External LLM output is considered untrusted.
5. User inputs and chatbot prompts may contain malicious instructions.

Threat Modelling Requirements:

Identify:

1. STRIDE-based threats
2. LLM-specific security threats
3. OWASP LLM Top 10 relevant threats
4. Threats related to trust boundaries
5. Threats related to:
 - prompt injection
 - sensitive information disclosure
 - insecure output handling
 - excessive agency
 - session security
 - authentication abuse
 - data leakage

For every threat provide:

- Threat ID
- Threat name
- STRIDE category
- Affected component/data flow
- Attack scenario
- Security impact
- Severity
- Likelihood
- Mitigation strategy
- Mapping to OWASP LLM Top 10 (if applicable)

Do not provide generic security advice. Every threat must be connected to this architecture.